

# Controls and compliance checklist

*Does Botium Toys currently have this control in place?*

## Controls assessment checklist

| Yes                                 | No                                  | Control                                                             |
|-------------------------------------|-------------------------------------|---------------------------------------------------------------------|
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Least Privilege                                                     |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Disaster recovery plans                                             |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Password policies                                                   |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Separation of duties                                                |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Firewall                                                            |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Intrusion detection system (IDS)                                    |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Backups                                                             |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Antivirus software                                                  |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Manual monitoring, maintenance, and intervention for legacy systems |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Encryption                                                          |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Password management system                                          |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Locks (offices, storefront, warehouse)                              |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Closed-circuit television (CCTV) surveillance                       |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Fire detection/prevention (fire alarm, sprinkler system, etc.)      |

---

## Compliance checklist

### Payment Card Industry Data Security Standard (PCI DSS)

| Yes                      | No                                  | Best practice                                                                                                |
|--------------------------|-------------------------------------|--------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Only authorized users have access to customers' credit card information.                                     |
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. |
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Implement data encryption procedures to better secure credit card transaction touchpoints and data.          |
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Adopt secure password management policies.                                                                   |

### General Data Protection Regulation (GDPR)

| Yes                                 | No                                  | Best practice                                                                                                     |
|-------------------------------------|-------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | E.U. customers' data is kept private/secured.                                                                     |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Ensure data is properly classified and inventoried.                                                               |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Enforce privacy policies, procedures, and processes to properly document and maintain data.                       |

### System and Organizations Controls (SOC type 1, SOC type 2)

| Yes                      | No                                  | Best practice                                      |
|--------------------------|-------------------------------------|----------------------------------------------------|
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | User access policies are established.              |
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Sensitive data (PII/SPII) is confidential/private. |

- ☒ ☐ Data integrity ensures the data is consistent, complete, accurate, and has been validated.
  - ☐ ☒ Data is available to individuals authorized to access it.
- 

There seems to be a lack of multiple controls which could potentially affect Botium Toys' security posture negatively. This leaves internally stored data vulnerable to tampering or theft and may result in asset loss. I recommend implementing the following controls immediately to further safeguard the online storefront: Encryption, a deterrent control, would provide confidentiality to sensitive information. Backups, a corrective control, would provide a recovery solution in the case of an event. An Intrusion Detection System (IDS), a detective control, would detect anomalous traffic.

To further strengthen the company's security posture, it is important to analyze employee access and identify areas for improvement while maintaining business continuity. By implementing a least privilege control in tandem with separation of duties, we can reduce the overall risk of leaking confidential information and prevent potential insider sabotage. Additionally, the current password requirements are too minimal, giving threat actors an easy point of entry. Improving the password policy and deploying a password management system alongside it will further harden this perimeter.

To tie these controls together, Botium Toys must properly classify its assets. This includes establishing a regular schedule for manual monitoring, maintenance, and intervention for legacy systems to ensure they are not at risk of a breach. Lastly, I recommend creating comprehensive disaster recovery plans to ensure business continuity in the event of an incident.